TRAIN-OFFICE · HSF302

# RailJet

## Tài liệu tổng quan và luồng nghiệp vụ

Toàn bộ những gì cần biết về dự án: chức năng, kiến trúc, dữ liệu, trạng thái, luồng khách hàng, luồng quản trị, quy tắc nghiệp vụ, bảo mật, cấu hình và danh sách đường dẫn.

Spring Boot 4 · Thymeleaf · SQL Server · Redis · VNPay · Google OAuth · Tesseract OCR

# Mục lục


**1. Tổng quan dự án** **3**

1.1 Hai vai trò người dùng . . . 3

1.2 Chức năng chính . . . 3

1.3 Công nghệ . . . 3

**2. Kiến trúc và cấu trúc mã nguồn** **4**

2.1 Gói (package) chính . . . 4

**3. Mô hình dữ liệu** **4**

**4. Trạng thái và vòng đời** **5**

4.1 Đơn đặt chỗ (Booking) . . . 5

4.2 Vé (Ticket) . . . 5

4.3 Thanh toán (Payment) và hoàn tiền (Refund) . . . 6

4.4 Chuyến, tàu, tài khoản . . . 6

**5. Luồng khách hàng** **6**

5.1 Tài khoản . . . 6

5.2 Đặt vé từ đầu đến cuối . . . 6

5.3 Sau khi đặt . . . 8

5.4 Hoàn tiền (phía khách) . . . 8

**6. Luồng quản trị (Admin)** **8**

6.1 Thiết lập dữ liệu nền (thứ tự nên làm) . . . 8

6.2 Bán hàng và tài chính . . . 9

6.3 Huỷ chuyến . . . 9

**7. Quy tắc nghiệp vụ** **10**

7.1 Tính giá . . . 10

7.2 Lịch chạy . . . 10

7.3 Giữ ghế và thời hạn . . . 10

7.4 Hoàn tiền . . . 10

**8. Redis, job nền và sự kiện** **11**

**9. Bảo mật** **11**

9.1 Rate limit (Redis) . . . 11

**10. Cài đặt, cấu hình và dữ liệu mẫu** **12**

10.1 Chạy dự án . . . 12

10.2 Dữ liệu mẫu khi khởi động (DataInitializer) . . . 12

10.3 Kiểm thử . . . 12

**11. Danh sách đường dẫn** **13**

11.1 Khách hàng và API . . . 13

11.2 Quản trị . . . 14

**12. Hạn chế và việc còn mở** **14**

# 1. Tổng quan dự án

**RailJet (Train-Office)** là website đặt vé tàu hoả trực tuyến, gồm hai phần: **trang khách hàng** để tìm chuyến, chọn ghế, nhập hành khách, thanh toán và quản lý vé; **trang quản trị** để nhà vận hành quản lý tàu, toa, ghế, ga, tuyến, chuyến chạy, thanh toán, hoàn tiền và chính sách giảm giá.

## 1.1 Hai vai trò người dùng

| Vai trò | Đăng nhập | Làm được gì |
|---|---|---|
| **CUSTOMER** (khách) | Email + mật khẩu, hoặc Google | Tìm chuyến (không cần đăng nhập); chọn ghế, đặt chỗ, thanh toán, xem/in vé, yêu cầu hoàn tiền, sửa hồ sơ (cần đăng nhập) |
| **ADMIN** | Email + mật khẩu | Mọi trang dưới `/admin/**`: danh mục tàu – toa – ghế – ga – tuyến, chuyến, thanh toán, hoàn tiền, ví, giảm giá, người dùng |

Tài khoản admin mặc định được tạo khi khởi động lần đầu: **admin@railjet.com / 123456**. Nên đổi mật khẩu ngay.

## 1.2 Chức năng chính

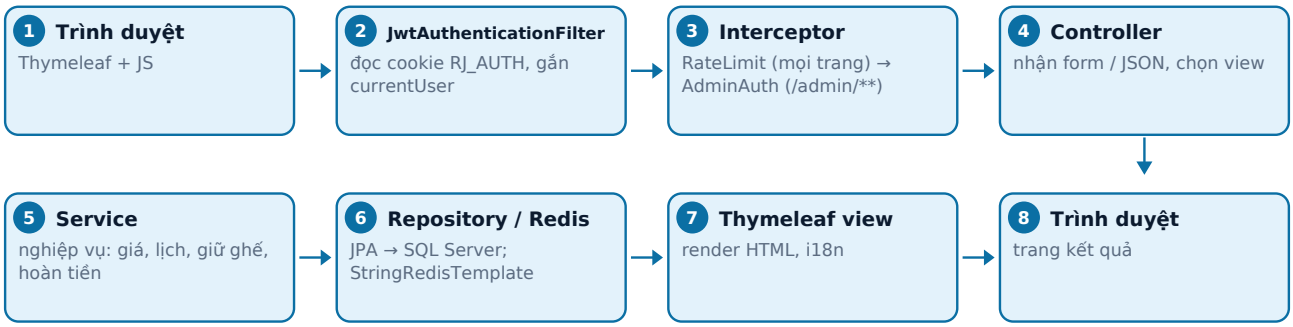
| Nhóm | Chức năng |
|---|---|
| Tìm chuyến | Một chiều hoặc khứ hồi theo ga đi, ga đến, ngày, số khách; gợi ý ga và ngày có chuyến; xem tất cả chuyến theo ngày |
| Chọn ghế | Sơ đồ theo toa, khoang (giường nằm có tầng); ghế đã bán / đang có người giữ / bảo trì không chọn được; giữ ghế bằng Redis có đồng hồ đếm ngược |
| Hành khách | Nhập thông tin từng người; quét CCCD tự điền (OCR); tự xác định đối tượng giảm giá theo ngày sinh |
| Giá | Giá chặng theo km, phụ thu toa, giảm giá theo đối tượng (độ tuổi) và giảm giá nhóm (số khách) |
| Thanh toán | VNPay Sandbox; 10 phút thanh toán sau khi đặt chỗ; vé chỉ xuất sau khi thanh toán thành công |
| Sau mua | Đặt chỗ của tôi, chi tiết đơn, huỷ đơn chưa thanh toán, vé của tôi, in vé, yêu cầu hoàn tiền 100% |
| Quản trị | Dashboard, CRUD tàu/toa/ghế/ga/tuyến/loại ghế/người dùng/hành khách, tạo chuyến với lịch dừng tự tính, duyệt hoàn tiền, ví admin, huỷ chuyến tự hoàn tiền |
| Hệ thống | Song ngữ Việt/Anh, JWT cookie, rate limit, quên mật khẩu qua email (mã 6 số), đăng nhập Google |

## 1.3 Công nghệ

| Lớp | Công nghệ |
|---|---|
| Ngôn ngữ / Framework | Java 17, Spring Boot 4 (Spring Framework 7), Spring MVC, Bean Validation |
| Giao diện | Thymeleaf (server-side render), Bootstrap 5.3, Bootstrap Icons, JavaScript thuần (fetch) |
| Dữ liệu | SQL Server, Spring Data JPA, Hibernate 7 (`ddl-auto=update`) |
| Bộ nhớ tạm | Redis 6+ (Lettuce): khoá ghế có thời hạn, bộ đếm rate limit |
| Bảo mật | JWT (nimbus-jose-jwt) trong cookie HttpOnly RJ_AUTH, BCrypt (spring-security-crypto), không dùng Spring Security filter chain |
| Tích hợp | VNPay Sandbox (HMAC-SHA512), Google OAuth 2.0, Gmail SMTP (Spring Mail), Tesseract OCR qua Tess4J |
| Kiểm thử | JUnit 5, Mockito, Spring Boot Test; test giữ ghế và rate limit chạy với Redis thật |

# 2. Kiến trúc và cấu trúc mã nguồn

Ứng dụng theo mô hình nhiều tầng của Spring MVC. Mọi request đi qua filter JWT, rồi các interceptor (rate limit, kiểm tra admin), tới controller; controller gọi service chứa nghiệp vụ; service dùng repository (JPA) với SQL Server và Redis cho khoá tạm.




## 2.1 Gói (package) chính

| Gói | Nội dung |
|---|---|
| `controller` | Controller trang khách, trang admin, API JSON (`/api/booking/**`) |
| `service`, `service/impl` | Interface và cài đặt nghiệp vụ: BookingFlow, BookingPricing, TripScheduleBuilder, RedisSeatHold, Payment, Refund, AdminWallet, Ocr… |
| `repository` | Spring Data JPA repository, truy vấn chồng chặng, tổng doanh thu |
| `entity` | Bảng dữ liệu (mục 3) |
| `dto` | Form, kết quả tìm chuyến, chặng (TripSegment), SeatHold, BookingSession… |
| `config` | DataInitializer (seed), WebMvcConfig, AdminAuthInterceptor, I18n |
| `security` | JwtService, AuthCookie, JwtAuthenticationFilter, CurrentUser |
| `ratelimit` | RateLimitRules (bảng giới hạn), RateLimitInterceptor |
| `scheduler`, `event` | Job huỷ đơn hết hạn; sự kiện nhả khoá Redis sau khi commit DB |
| `common` | Enum trạng thái, BookingHoldPolicy (các mốc thời gian giữ chỗ) |
| `templates` | View Thymeleaf: booking/, payments/, tickets/, refunds/, admin/, fragments/… |

# 3. Mô hình dữ liệu

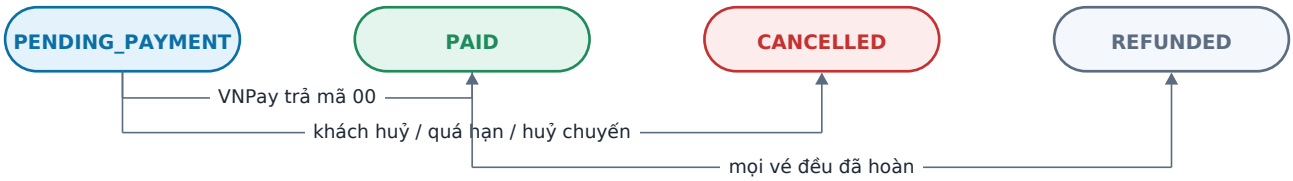
Quan hệ chính: **Tàu** có nhiều **Toa**, toa có **Khoang** (giường nằm) và **Ghế**. **Tuyến** là danh sách **Ga** theo thứ tự kèm km. **Chuyến** = một tàu chạy một tuyến tại một giờ, có **lịch dừng** từng ga. **Đơn đặt chỗ** thuộc một chuyến và một chặng (ga lên → ga xuống), gồm **Hành khách**, mỗi người một **Vé** gắn với một ghế; đơn có các lần **Thanh toán**; vé có thể có **Yêu cầu hoàn tiền**.

| Bảng (entity) | Ý nghĩa | Trường đáng chú ý |
|---|---|---|
| Province, Station | Tỉnh/thành và ga | mã ga, tên, thành phố |
| Route, RouteStation | Tuyến và ga thuộc tuyến | thứ tự ga, khoảng cách km từ ga đầu |
| Train | Tàu | mã, tên, trạng thái, **tốc độ trung bình km/h** (20–300) |
| Coach, Compartment, Seat | Toa, khoang, ghế | loại toa, sức chứa, **giá ghế của toa**; ghế: số ghế, tầng giường, phụ thu, **under_maintenance** |
| SeatType | Danh mục loại ghế | tên, mô tả |

| Bảng (entity) | Ý nghĩa | Trường đáng chú ý |
|---|---|---|
| TrainTrip, TripStation | Chuyến và lịch dừng | tàu, tuyến, giờ khởi hành, giá cơ bản, trạng thái; giờ đến/đi từng ga |
| Booking | Đơn đặt chỗ | mã đơn RJ…, chuyến, ga lên/xuống, người đặt, tổng tiền, trạng thái, giờ đặt |
| Passenger | Hành khách của đơn | họ tên, ngày sinh, giới tính, CCCD, đối tượng, quan hệ với người đặt |
| Ticket | Vé (một hành khách, một ghế) | mã vé, giá đã chốt (đã chia giảm giá nhóm), trạng thái |
| Payment | Lần thanh toán | id UUID (= vnp_TxnRef), số tiền, mã giao dịch VNPay, trạng thái, giờ trả |
| Refund | Yêu cầu hoàn tiền | mã RF…, số tiền, lý do, thông tin ngân hàng, trạng thái, processedAt, refundedAt |
| AdminWallet, AdminWalletTransaction | Ví quản trị và lịch sử | số dư; giao dịch CREDIT/DEBIT, số dư sau, mã tham chiếu |
| DiscountPolicy | Giảm giá theo đối tượng | mã, khoảng tuổi, % giảm, thứ tự ưu tiên |
| GroupDiscountPolicy | Giảm giá nhóm | số khách tối thiểu/tối đa, % giảm |
| User, PasswordResetCode | Tài khoản, mã quên mật khẩu | email, vai trò, trạng thái; mã 6 số hết hạn 10 phút |
| Invoice | Hoá đơn | có entity và template nhưng **chưa có luồng sử dụng** |

# 4. Trạng thái và vòng đời

## 4.1 Đơn đặt chỗ (Booking)




## 4.2 Vé (Ticket)



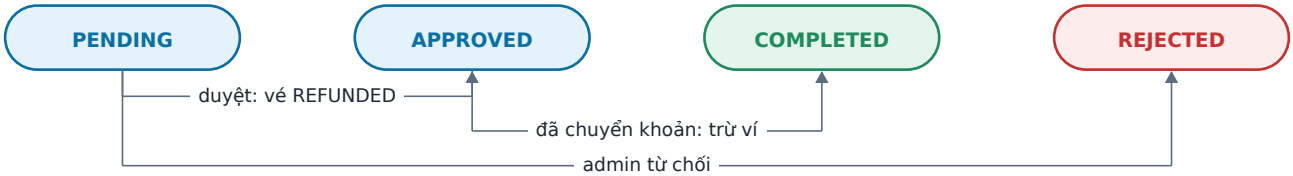

**BOOKED** (hiển thị "Đang giữ chỗ") là bản ghi nội bộ giữ ghế và giá cho đơn chưa thanh toán; khách **không thấy** vé này ở "Vé của tôi". Vé ACTIVE, CHECKED_IN, EXPIRED là giá trị cũ từ dữ liệu mẫu, không còn dùng.

## 4.3 Thanh toán (Payment) và hoàn tiền (Refund)

**Thanh toán (Payment)**




**Hoàn tiền (Refund)**




Thanh toán SUCCESS bị khoá: không sửa số tiền/trạng thái, không xoá, không đánh dấu thất bại. Admin **không thể** tự đánh dấu thành công, chỉ VNPay mới làm được.

## 4.4 Chuyến, tàu, tài khoản

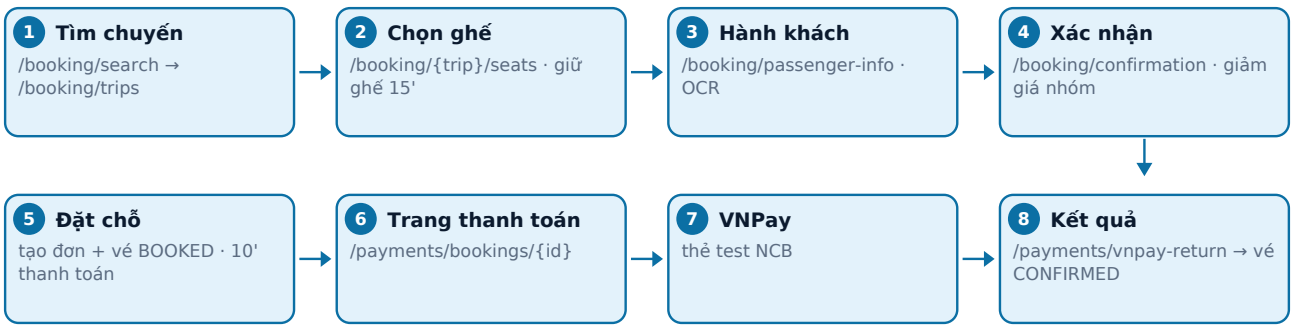
| Đối tượng | Trạng thái | Ghi chú |
|---|---|---|
| Chuyến (TripStatus) | SCHEDULED, CANCELLED, COMPLETED | Chỉ chuyến SCHEDULED mới bán vé và hoàn tiền theo yêu cầu. Huỷ chuyến chỉ qua nút "Huỷ chuyến". COMPLETED **chưa có job tự đặt**. |
| Tàu (TrainStatus) | AVAILABLE, ON_TRIP, MAINTENANCE | Tàu bảo trì hoặc chưa có tốc độ không được dùng để seed chuyến mẫu. |
| Tài khoản (UserStatus) | ACTIVE, LOCKED, INACTIVE | Vai trò: ADMIN, CUSTOMER. |

# 5. Luồng khách hàng

## 5.1 Tài khoản

- **Đăng ký** `/register` → **đăng nhập** `/login`: đúng mật khẩu thì server cấp JWT lưu trong cookie HttpOnly RJ_AUTH (hạn 480 phút, tự gia hạn khi cũ). Có tham số `redirect` để quay lại trang đang mua vé.
- **Google**: `/oauth2/login/google` → Google → `/google-login`: kiểm tra state chống CSRF, đổi code lấy token, đọc email; chưa có tài khoản thì tự tạo CUSTOMER.
- **Quên mật khẩu**: nhập email → nhận mã 6 số (hết hạn 10 phút, gửi lại cách nhau ≥ 60 giây) → `/reset-password` nhập mã và mật khẩu mới. Chưa cấu hình mail thì mã in ra console.
- **Hồ sơ** `/profile`, **đổi mật khẩu** `/change-password`, **đổi ngôn ngữ** `/language/vi|en`, **đăng xuất** `/logout`.

## 5.2 Đặt vé từ đầu đến cuối



### Bước 1 – Tìm chuyến

- Nhập ga đi, ga đến, ngày, số khách (1–10), tuỳ chọn khứ hồi. API `/api/booking/station-availability` gợi ý ga và ngày có chuyến.
- Kết quả chỉ gồm chuyến SCHEDULED có đi qua cả hai ga theo đúng thứ tự; hiện giờ đi/đến của chặng và **giá chặng**. `/booking/all-trips` xem mọi chuyến theo ngày.
- Tìm chuyến không cần đăng nhập; bấm chọn ghế khi chưa đăng nhập sẽ chuyển sang trang đăng nhập rồi quay lại.

### Bước 2 – Chọn ghế (giữ ghế bằng Redis)

- Sơ đồ ghế theo toa/khoang. Ghế **không chọn được** khi: đã có vé BOOKED/CONFIRMED chồng chặng (DB), đang bị người khác giữ (Redis), hoặc đang bảo trì.
- Bấm một ghế → POST `/api/booking/holds/seats` khoá ghế trong Redis. **Ghế đầu tiên** bắt đầu đồng hồ **15 phút**; ghế chọn thêm dùng chung hạn. Bỏ chọn → DELETE; bỏ hết ghế đồng hồ vẫn chạy (không được thêm giờ). Số ghế giữ tối đa = số hành khách.
- Tải lại trang: ghế đang giữ được chọn sẵn, đồng hồ lấy thời gian còn lại từ Redis. Mỗi 30 giây trang hỏi lại `/api/booking/holds/current`.
- Hết giờ: popup "Hết thời gian giữ ghế", sau 10 giây tự về trang tìm vé. Chọn chuyến/chặng khác thì lượt giữ cũ bị huỷ.
- Bấm "Tiếp tục": ghế gửi lên phải đúng các ghế đang giữ trong Redis; thông tin chặng và ghế lưu vào session (BookingSession).

### Bước 3 – Hành khách

- Một form cho mỗi ghế; người đặt được điền sẵn ở hành khách đầu. Đối tượng giảm giá (trẻ em, người cao tuổi…) **do server tự xác định theo ngày sinh**, không tin giá trị từ trình duyệt.
- Dưới 16 tuổi bắt buộc nhập quan hệ với người đặt; từ 16 tuổi bắt buộc số CCCD. Ngày sinh tương lai bị từ chối.
- **Quét CCCD**: chọn/chụp ảnh mặt trước → POST `/booking/ocr-cccd` → Tesseract đọc 2 lượt (chữ và số) → tự điền họ tên, số CCCD, ngày sinh, giới tính; khách kiểm tra lại.

### Bước 4 – Xác nhận và đặt chỗ

- Trang xác nhận tính lại giá, kiểm tra ghế còn trống, cho chọn **giảm giá nhóm** phù hợp với số khách (`/booking/group-discount`).
- Bấm đặt chỗ: kiểm tra khoá Redis còn hạn → tạo Booking (PENDING_PAYMENT), Passenger, Ticket (BOOKED) với giá đã chốt → chuyển khoá ghế sang đơn và **đặt lại hạn thành 10 phút kể từ lúc đặt**.
- Mỗi tài khoản tối đa **2 đơn chưa thanh toán** cùng lúc.
- Trang thành công, "Đặt chỗ của tôi" và chi tiết đơn hiện **"Vui lòng thanh toán trước HH:mm, dd/MM/yyyy"**; quá hạn chuyển màu đỏ.

### Bước 5 – Thanh toán VNPay




| Kết quả | Hệ thống làm gì |
|---|---|
| Mã 00, đơn còn chờ | Payment SUCCESS, Booking PAID, vé BOOKED → CONFIRMED, cộng tiền vào ví admin, xoá khoá Redis (sau commit). |

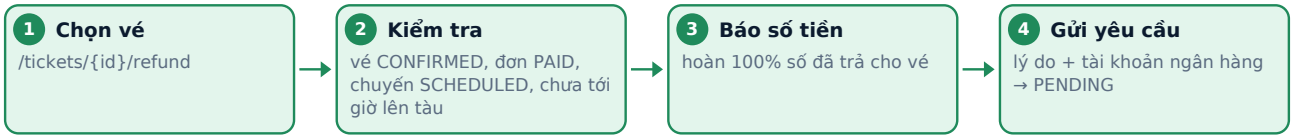
| Kết quả | Hệ thống làm gì |
|---|---|
| Mã 00 nhưng đơn đã huỷ/đã trả | Vẫn ghi nhận tiền vào ví; tự tạo yêu cầu hoàn tiền **APPROVED** cho từng vé để admin chuyển trả khách. |
| Mã khác / khách huỷ | Payment FAILED, khoá Redis quay về hạn thanh toán ban đầu (đã qua thì nhả ghế). |
| Sai chữ ký / thiếu chữ ký | Payment FAILED, không đổi đơn. |

Thẻ test VNPay Sandbox: ngân hàng **NCB**, số thẻ **9704198526191432198**, chủ thẻ **NGUYEN VAN A**, ngày phát hành **07/15**, OTP **123456**.

### 5.3 Sau khi đặt

- **Đặt chỗ của tôi** `/booking/history`: lọc theo trạng thái; đơn chờ thanh toán có nút thanh toán và hạn thanh toán.
- **Chi tiết đơn** `/booking/{id}`: hành trình, hành khách, "Ghế đã chọn" (chưa thanh toán) hoặc "Vé" (đã thanh toán); huỷ đơn chưa thanh toán bằng POST `/booking/{id}/cancel` (nhả ghế ngay).
- **Vé của tôi** `/tickets`: chỉ vé CONFIRMED và REFUNDED. Xem `/tickets/{id}`, in `/tickets/{id}/print` (chỉ vé CONFIRMED).

### 5.4 Hoàn tiền (phía khách)




- Số tiền hoàn = giá vé đã chốt (đã chia giảm giá nhóm). Vé cũ trước khi chia giá: chia tổng đơn theo tỉ lệ giá vé, không vượt giá vé.
- Mỗi vé chỉ có một yêu cầu đang mở. Khách vãng lai (không đăng nhập) chưa hỗ trợ hoàn tiền.

## 6. Luồng quản trị (Admin)

Mọi trang dưới `/admin/**` được **AdminAuthInterceptor** chặn: chưa đăng nhập hoặc không phải ADMIN thì không vào được. Thao tác thay đổi dữ liệu (xoá, huỷ, đánh dấu…) đều là **POST** có hộp xác nhận, không dùng link GET.

### 6.1 Thiết lập dữ liệu nền (thứ tự nên làm)




| Trang | Đường dẫn | Ghi chú nghiệp vụ |
|---|---|---|
| Dashboard | /admin | Doanh thu hôm nay (= thanh toán SUCCESS hôm nay − hoàn tiền COMPLETED hôm nay), số đơn, yêu cầu hoàn đang chờ, đơn gần đây, chuyến sắp chạy |
| Ga | /admin/stations | Mã, tên, tỉnh/thành. Không xoá được ga đang dùng trong tuyến. |

| Trang | Đường dẫn | Ghi chú nghiệp vụ |
|---|---|---|
| Tuyến | /admin/routes | Mã, tên; ga của tuyến ở `/admin/routes/{id}/stations`: thứ tự, km tính từ ga đầu, sắp xếp lại. |
| Tàu | /admin/trains | Mã, tên, trạng thái, **tốc độ trung bình (20–300 km/h)** dùng để tính lịch. |
| Toa | /admin/coaches | Loại toa, sức chứa, khoang (giường nằm), **giá ghế/giường của toa (bắt buộc)**. Lưu toa thì sinh ghế tương ứng. |
| Ghế | /admin/seats | Xem theo tàu/toa. Không xoá ghế; bật/tắt **bảo trì** để tạm khoá ghế hỏng. |
| Loại ghế | /admin/seat-types | Danh mục loại ghế. |
| Chuyến | /admin/trips | Chỉ cần chọn tàu + tuyến + giờ khởi hành; xem trước giờ từng ga (`/admin/trips/schedule-preview`). Không đổi tuyến khi chuyến đã có đơn. Không đặt "Đã huỷ" ở form sửa. |
| Lịch dừng | /admin/trips/{id}/stations | Sửa giờ từng ga, sinh lại lịch (`/generate`). |
| Huỷ chuyến | POST /admin/trips/{id}/cancel | Mục 6.3. |

## 6.2 Bán hàng và tài chính

| Trang | Đường dẫn | Ghi chú nghiệp vụ |
|---|---|---|
| Thanh toán | /admin/payments | Lọc theo trạng thái/đơn, xem chi tiết, sửa giao dịch PENDING, đánh dấu FAILED, xoá giao dịch chưa thành công. Giao dịch SUCCESS bị khoá. |
| Hoàn tiền | /admin/refunds | Danh sách cần xử lý (PENDING + APPROVED) và lịch sử ví. Duyệt → chuyển khoản ngoài hệ thống → bấm Hoàn tất (trừ ví). Hoặc Từ chối. |
| Hành khách | /admin/passengers | Xem / sửa / xoá hành khách (không xoá được khi đang có vé). |
| Người dùng | /admin/users | Tạo, sửa vai trò/trạng thái, khoá tài khoản; không tự xoá chính mình. |
| Giảm giá đối tượng | /admin/discount-policies | Khoảng tuổi + % giảm; áp dụng tự động theo ngày sinh hành khách. |
| Giảm giá nhóm | /admin/group-discount-policies | Số khách tối thiểu/tối đa + % giảm; khách tự chọn ở trang xác nhận. |

### Ví quản trị

- **Cộng**: mỗi thanh toán VNPay thành công. **Trừ**: khi hoàn tất hoàn tiền (thủ công hoặc tự động khi huỷ chuyến).
- Mọi thay đổi ghi vào `admin_wallet_transactions`; khoá dòng ví (PESSIMISTIC_WRITE) khi cộng/trừ; số dư không đủ thì thao tác bị huỷ toàn bộ.

## 6.3 Huỷ chuyến



Ví không đủ tiền để hoàn thì **không huỷ gì cả** và báo lỗi. Hoàn tất ở đây nghĩa là hệ thống coi như đã trả; admin vẫn tự chuyển khoản cho khách (yêu cầu tự tạo chưa có số tài khoản ngân hàng). Khách đang thanh toán dở mà VNPay vẫn báo thành công sẽ được tạo yêu cầu hoàn APPROVED.

# 7. Quy tắc nghiệp vụ

## 7.1 Tính giá

| Thành phần | Công thức |
|---|---|
| Giá chặng | Giá cơ bản của chuyến × (km chặng ÷ km cả tuyến), làm tròn đến 1.000đ, **tối thiểu 50.000đ** (hoặc bằng giá cơ bản nếu thấp hơn), không vượt giá cơ bản. |
| Giá gốc một vé | Giá chặng + phụ thu ghế (giá ghế/giường của toa). |
| Giảm giá đối tượng | % theo chính sách khớp với tuổi hành khách (tính theo ngày sinh), trừ trên từng vé. |
| Giảm giá nhóm | % trên tổng sau giảm đối tượng; phần giảm được **chia cho từng vé** theo tỉ lệ giá để tổng giá vé đúng bằng tổng đơn. |
| Số tiền gửi VNPay | Tổng đơn × 100 (quy định VNPay). |

## 7.2 Lịch chạy

- Giờ đến ga kế = giờ rời ga trước + (khoảng cách km ÷ tốc độ tàu); dừng **5 phút** ở mỗi ga trung gian.
- Sửa giờ khởi hành, tàu hoặc tuyến thì lịch tự tính lại; đổi tuyến xoá lịch cũ và sinh lịch mới.

## 7.3 Giữ ghế và thời hạn

| Mốc | Thời gian | Hết hạn thì |
|---|---|---|
| Chọn ghế → xác nhận | 15 phút từ ghế đầu tiên (không gia hạn khi chọn thêm/bỏ ghế) | Popup + về trang tìm vé; Redis tự xoá khoá |
| Đặt chỗ → bắt đầu thanh toán | 10 phút kể từ lúc đặt | Không tạo được link VNPay; job huỷ đơn |
| Đang ở trang VNPay | +20 phút (link VNPay 15' + 5' dự phòng), chỉ khi bắt đầu trước hạn 10' | Thất bại: quay về hạn 10' |
| Job dọn đơn | Chạy mỗi 60 giây; đơn mới tạo được miễn 60 giây | Đơn PENDING_PAYMENT không còn khoá Redis → CANCELLED |

Ghế bị khoá theo **từng đoạn giữa hai ga liền nhau**, nên người đi chặng không chồng lên vẫn mua được cùng ghế. Kiểm tra trùng ghế dùng cả DB (vé BOOKED/CONFIRMED chồng chặng) và Redis (khoá của người khác).

## 7.4 Hoàn tiền

- Duyệt hoàn tiền: vé REFUNDED (ghế nhả ngay), đơn REFUNDED nếu mọi vé đã hoàn. Hoàn tất: trừ ví, ghi refundedAt.
- Hoàn 100% số khách đã trả, không có phí hoàn theo thời gian; chỉ hoàn được trước giờ tàu rời ga lên.

# 8. Redis, job nền và sự kiện

| Key Redis | Ý nghĩa | TTL |
|---|---|---|
| `rj:seat:{t<tripId>}:<seatId>:<leg>` | Khoá một đoạn của một ghế; value = u:<userId> (đang chọn) hoặc b:<bookingId> (đơn) | Theo hạn giữ chỗ |
| `rj:hold:u:<userId>` | Lượt giữ của khách: chuyến, chặng, danh sách ghế | 15 phút |
| `rj:hold:b:<bookingId>` | Khoá của đơn + holdUntil (hạn thanh toán) | 10 phút / +20 khi thanh toán |
| `rj:rl:<rule>:<subject>` | Bộ đếm rate limit (cửa sổ cố định) | Độ dài cửa sổ |

- Các thao tác nhiều key dùng **script Lua** để Redis chạy một mạch (khoá đủ mọi đoạn hoặc không khoá đoạn nào; chuyển chủ khoá; gia hạn).
- **BookingHoldCleanupTask** (mỗi 60 giây): huỷ đơn chờ thanh toán đã hết khoá. Redis lỗi thì bỏ qua lượt chạy, không huỷ nhầm.
- **SeatHoldReleaseEvent**: nhả khoá Redis **sau khi DB commit** (huỷ đơn, thanh toán xong, đơn hết hạn, huỷ chuyến).
- Log tiền tố `[SeatHold]` và `[RateLimit]` để theo dõi.

# 9. Bảo mật

- **JWT** ký HS256 bằng `JWT_SECRET`, nằm trong cookie HttpOnly, SameSite=Lax. Filter đọc cookie, nạp User và đặt vào request (`CurrentUser`).
- **Phân quyền admin**: AdminAuthInterceptor trên `/admin/**`.
- **Chống CSRF đơn giản**: mọi thao tác thay đổi dữ liệu dùng POST; cookie SameSite=Lax không gửi kèm POST từ trang khác.
- **Mật khẩu** băm BCrypt. Đăng nhập Google dùng state chống giả mạo.
- **VNPay**: kiểm chữ ký HMAC-SHA512 và số tiền khi nhận kết quả.

## 9.1 Rate limit (Redis)

| Quy tắc | Endpoint | Giới hạn |
|---|---|---|
| login-ip / login-email | POST /login | 10/phút/IP và 10/15 phút/email |
| google-login | GET /oauth2/login/google, /google-login | 20/phút/IP |
| register | POST /register | 5/giờ/IP |
| forgot-email / forgot-ip | POST /forgot-password, /reset-password/resend | 3/15 phút/email; 10/giờ/IP |
| reset-password | POST /reset-password | 10/15 phút/IP |
| ocr | POST /booking/ocr-cccd | 10/phút/tài khoản |
| seat-hold / seat-hold-status | /api/booking/holds/** | 60/phút/tài khoản |
| booking-steps | POST /booking/seat-selection, /booking/confirmation | 10/phút/tài khoản |
| payment | POST /payments/bookings/* | 5/phút/tài khoản |
| trip-search | /booking/trips, /api/booking/station-availability | 60/phút/IP |

Vượt giới hạn: API trả 429 + Retry-After (JSON); trang thường hiện trang "Quá nhiều yêu cầu" đếm ngược rồi tự quay lại trang trước. Cửa sổ bắt đầu từ request đầu tiên, Redis tự xoá key khi hết hạn. Tắt bằng `RATE_LIMIT_ENABLED=false`.

# 10. Cài đặt, cấu hình và dữ liệu mẫu

## 10.1 Chạy dự án




| Biến môi trường | Dùng cho |
|---|---|
| `JWT_SECRET` | Khoá ký JWT (base64, ≥ 32 byte) |
| `MAIL_HOST, MAIL_PORT, MAIL_USERNAME, MAIL_PASSWORD, MAIL_FROM` | Gửi mã quên mật khẩu (Gmail App Password) |
| `VNPAY_TMN_CODE, VNPAY_SECRET_KEY, VNPAY_PAY_URL, VNPAY_RETURN_URL` | Thanh toán VNPay Sandbox |
| `GOOGLE_CLIENT_ID, GOOGLE_CLIENT_SECRET, GOOGLE_REDIRECT_URI` | Đăng nhập Google (redirect `/google-login`) |
| `REDIS_HOST, REDIS_PORT, REDIS_PASSWORD, REDIS_DATABASE` | Kết nối Redis (mặc định localhost:6379, không mật khẩu, DB 0) |
| `RATE_LIMIT_ENABLED` | Bật/tắt rate limit |

Cấu hình khác trong `application.properties`: cổng 8081, `ocr.tessdata-path`, `ocr.language=vie+eng`, vùng crop OCR, giới hạn upload 10MB, i18n.

## 10.2 Dữ liệu mẫu khi khởi động (DataInitializer)

- Luôn đảm bảo có tài khoản admin và ví admin.
- **Chỉ khi bảng còn trống**: 34 tỉnh/thành và ga mẫu; tàu kèm toa, khoang, ghế; 7 tuyến mẫu (HN–SG, HN–HP–QN, HN–Tây Bắc, ĐN–Huế–QT, ĐN–Tây Nguyên–HCM, HCM–miền Tây, HCM–Nha Trang). Sửa đổi của admin không bị ghi đè.
- Bổ sung giá trị còn thiếu cho DB cũ: tốc độ tàu, giá ghế của toa.
- Thêm chuyến mẫu cho các ngày sắp tới nếu chưa có; không sửa chuyến cũ.

## 10.3 Kiểm thử

- `mvnw test`. Test Redis (`RedisSeatHoldServiceTest`, `RedisRateLimitTest`) cần Redis thật, dùng database 15 và tiền tố key riêng, tự dọn sau khi chạy.
- Tài liệu kèm theo: `HUONG-DAN-REDIS.md`, `Userguide for google login, ocr, vnpay sandbox.md`, `HUONG-DAN-SETUP-OCR-CCCD.md`.

# 11. Danh sách đường dẫn

## 11.1 Khách hàng và API

| Method | Đường dẫn | Chức năng |
|---|---|---|
| GET | / | Trang chủ |
| GET/POST | /login, /register, /logout | Đăng nhập, đăng ký, đăng xuất |
| GET/POST | /forgot-password, /reset-password, /reset-password/resend | Quên mật khẩu |
| GET | /oauth2/login/google, /google-login | Đăng nhập Google |
| GET/POST | /profile, /change-password | Hồ sơ, đổi mật khẩu |
| GET | /language/{lang} | Đổi ngôn ngữ |
| GET | /booking/search | Form tìm chuyến |
| GET/POST | /booking/trips | Kết quả tìm chuyến (một chiều/khứ hồi) |
| GET | /booking/all-trips | Mọi chuyến theo ngày |
| GET | /booking/{tripId}/seats | Chọn ghế |
| POST | /booking/seat-selection | Xác nhận ghế đã giữ |
| GET/POST | /booking/passenger-info | Thông tin hành khách |
| POST | /booking/ocr-cccd | Quét CCCD (JSON) |
| GET/POST | /booking/confirmation | Xác nhận / tạo đơn |
| POST | /booking/group-discount | Chọn/bỏ giảm giá nhóm |
| GET | /booking/success?bookingId= | Đặt chỗ thành công |
| GET | /booking/history, /booking/{id} | Đặt chỗ của tôi, chi tiết đơn |
| POST | /booking/{id}/cancel | Huỷ đơn chưa thanh toán |
| GET/POST | /payments/bookings/{id} | Trang thanh toán / tạo link VNPay |
| GET | /payments/vnpay-return | VNPay trả kết quả |
| GET | /tickets, /tickets/{id}, /tickets/{id}/print | Vé của tôi, xem, in |
| GET/POST | /tickets/{id}/refund | Yêu cầu hoàn tiền |
| GET | /api/booking/station-availability | Gợi ý ga và ngày (JSON) |
| POST/DELETE | /api/booking/holds/seats[/{seatId}] | Giữ / bỏ ghế (JSON) |
| GET | /api/booking/holds/current[?bookingId=] | Thời gian giữ còn lại (JSON) |
| * | /rate-limited | Trang "Quá nhiều yêu cầu" (nội bộ) |

### 11.2 Quản trị

| Method | Đường dẫn | Chức năng |
|---|---|---|
| GET | `/admin, /admin/dashboard` | Dashboard |
| GET/POST | `/admin/stations[/new\|/edit/{id}\|/save\|/delete/{id}]` | Ga |
| GET/POST | `/admin/routes[...]` | Tuyến |
| GET/POST | `/admin/routes/{id}/stations[/new\|/save\|/edit/{rs}\|/update/{rs}\|/reorder\|/delete/{rs}]` | Ga của tuyến |
| GET/POST | `/admin/trains[...]` | Tàu |
| GET/POST | `/admin/coaches[...]` | Toa (sinh ghế) |
| GET / POST | `/admin/seats, /admin/seats/{id}/maintenance` | Ghế, bật/tắt bảo trì |
| GET/POST | `/admin/seat-types[...]` | Loại ghế |
| GET/POST | `/admin/trips, /create, /save, /{id}, /{id}/edit, /{id}/update` | Chuyến |
| GET | `/admin/trips/schedule-preview` | Xem trước lịch (JSON) |
| POST | `/admin/trips/{id}/cancel` | Huỷ chuyến + tự hoàn tiền |
| GET/POST | `/admin/trips/{id}/stations[/create\|/save\|/{ts}/edit\|/{ts}/update\|/{ts}/delete\|/generate]` | Lịch dừng |
| GET/POST | `/admin/payments, /edit/{id}, /save, /detail/{id}, /failed/{id}, /delete/{id}` | Thanh toán |
| GET/POST | `/admin/refunds, /{id}, /{id}/approve, /{id}/reject, /{id}/complete` | Hoàn tiền |
| GET/POST | `/admin/passengers[...]` | Hành khách |
| GET/POST | `/admin/users[...]` | Người dùng |
| GET/POST | `/admin/discount-policies[...], /admin/group-discount-policies[...]` | Giảm giá |

`[...]` = bộ CRUD chuẩn: danh sách (GET gốc), `/new`, `/edit/{id}`, `POST /save`, `POST /delete/{id}`.

# 12. Hạn chế và việc còn mở

| Vấn đề | Ảnh hưởng / gợi ý |
|---|---|
| Chuyến không tự chuyển COMPLETED | Cần job đóng chuyến đã qua giờ đến; hiện chặn hoàn tiền bằng giờ lên tàu. |
| Chưa có VNPay IPN | Khách đóng trình duyệt sau khi trả tiền thì đơn không được xác nhận; nên thêm endpoint IPN. |
| Chưa gửi email đặt vé / thanh toán / hoàn tiền | MailService đã có (dùng cho quên mật khẩu), có thể tận dụng. |
| Hoá đơn (Invoice) chưa dùng | Có entity và template nhưng chưa có luồng. |
| Khách vãng lai | Template tra cứu/huỷ đơn khách vãng lai còn sót, chưa có controller; khách vãng lai không thanh toán và không hoàn tiền được. |
| Bảo trì ghế đã bán | Bật bảo trì không xử lý vé tương lai đã bán cho ghế đó. |
| OCR | Log mức INFO ghi toàn bộ văn bản CCCD (dữ liệu cá nhân); có thể đọc mã QR trên CCCD gắn chip để chính xác hơn. |
| Múi giờ | Dùng giờ máy chủ (LocalDateTime.now()); deploy máy chủ UTC sẽ lệch 7 giờ. |
| Cột cũ | Bảng tickets còn cột is_ordered, ordered_until không dùng (vô hại, có thể xoá). |